

Day 16 Mini Project: Suspicious Email Investigation (Phishing Lure)

Oct 2, 2026 · Daniel Thibodeaux

Findings

A simulated credential-phishing lure impersonating "Microsoft Support Team" was sent from a Gmail account and quarantined by Exchange Online Protection as High Confidence Phish. It never reached the recipient's mailbox.

- **Time sent:** 2026-10-02 17:43:21 UTC
- **Time received by EOP / quarantined:** 2026-10-02 17:43:30 UTC
- **Recipient:** richard.hale@30daychallenge1870.onmicrosoft.com
- **Sender display name:** Microsoft Support Team
- **Sender address (IOC):** phishingmydfir[.]gmail[.]com
- **Subject:** Action required: your password expires today
- **Message ID:**
<CAEUzTv_+qzta+cLBDf2O=2XD0yQErZ5z0TaWEX7n+EAHth+ujw@mail.gmail.com>
- **Authentication:** SPF pass, DKIM pass, DMARC pass (all for gmail.com)
- **Verdict:** Quarantine reason High Confidence Phish, Policy Type: Anti-spam policy
- **Quarantine status:** Needs review, expires 2026-10-17
- **URL / attachment / hash IOCs:** none (the message was sent as plain text and the hyperlink did not survive)
- **Malware family:** not applicable (social-engineering lure, no payload)

Investigation Summary

This was a controlled lab simulation. On 2026-10-02 at 10:43:21 PDT (17:43:21 UTC), an external Gmail account with the display name "Microsoft Support Team" emailed richard.hale@30daychallenge1870.onmicrosoft.com. The message used urgency ("password expires today"), a 48-hour deadline, a threat of account loss, and a sign-in request. Exchange Online Protection received it at 17:43:30 UTC and quarantined it as High Confidence Phish under the Anti-spam policy.

The header analysis shows the sender was not spoofing a domain. SPF, DKIM, and DMARC all passed for gmail.com, so this was a real Gmail account abusing a Microsoft brand name in the display name. Passing authentication does not make a message legitimate. The message body contains no working URL and no attachment, so there are no URL, domain, or file-hash IOCs to scope on.

Because the message was held in quarantine, it was never delivered to Richard's Inbox or Junk folder, and there was no opportunity for him to click anything. Based on the evidence provided, the activity is contained. Searches for other recipients and for Richard's sign-in activity are listed under Recommendations as follow-up checks.

Who, What, When, Where, Why, How

- **Who:** The sender was the external account phishingmydfir@gmail[.]com, displayed as "Microsoft Support Team". The target was richard.hale@30daychallenge1870.onmicrosoft.com, who did not receive or interact with the message.
- **What:** A credential-phishing style lure titled "Action required: your password expires today" was sent and quarantined as High Confidence Phish. No URL or attachment was present in the delivered plain-text body.
- **When:** Sent 2026-10-02 at 17:43:21 UTC and quarantined at 17:43:30 UTC. Based on the evidence provided, the activity is not ongoing, and the message expires from quarantine on 2026-10-17.
- **Where:** The message was stopped at Exchange Online Protection in the 30daychallenge1870 tenant. It was never placed in Richard's mailbox, as confirmed by his Inbox view and the Quarantine entry.
- **Why:** The intent was to simulate a phishing lure for a lab exercise. A real attacker would use this pattern to push a user toward a fake sign-in page to harvest credentials.
- **How:** The sender used a free Gmail account with a brand-impersonating display name, urgency, and a threat of account loss. Gmail passed SPF, DKIM, and DMARC, so the message was caught by content-based detection rather than failing authentication.

Recommendations

1. **Do not release the quarantined message.** Keep it as evidence until it expires or the case is closed, then delete it.
2. **Scope the sender across the tenant.** In Explorer or Advanced Hunting, search EmailEvents on SenderFromAddress = phishingmydfir@gmail.com and on the Message ID, and review RecipientEmailAddress, LatestDeliveryLocation, and DeliveryAction. Isolate any other recipients and remove delivered copies.
3. **Check for post-event identity activity.** Review SigninLogs for richard.hale around 17:43 UTC for unfamiliar IPs, locations, or failed and successful sign-ins. Reset credentials only if anything unusual appears.
4. **Block the sender address.** Add phishingmydfir@gmail.com to the Tenant Allow/Block List. Do not block the connecting IP, because it belongs to Google's shared mail infrastructure.
5. **Raise awareness of the lure pattern.** A "Microsoft Support" display name on a freemail address with urgency and an account-loss threat is a reportable pattern. Remind users to use the Report button in Outlook.
6. **Improve visibility for next time.** Consider an anti-phishing policy that flags display-name impersonation of Microsoft from external senders.

Supporting Evidence

Screenshots

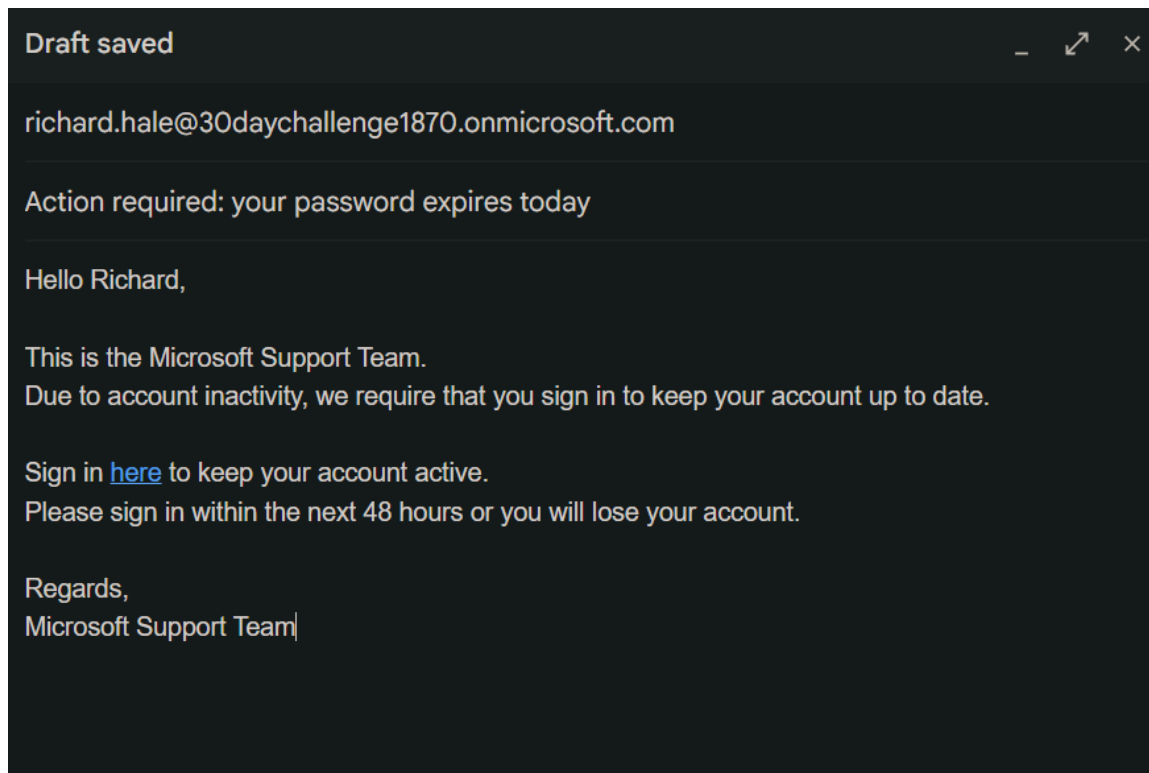


Figure 1: Lure composed in Gmail, addressed to Richard Hale. Notice the hyperlink successfully implemented.

Original Message	
Message ID	<CAEUzTv_+qzta+cLBDf2O=2XD0yQErZ5z0TaWEX7n+EAHth+ujw@mail.gmail.com>
Created at:	Fri, Oct 2, 2026 at 10:43 AM (Delivered after 0 seconds)
From:	Microsoft Support Team <phishingmydfir@gmail.com>
To:	richard.hale@30daychallenge1870.onmicrosoft.com
Subject:	Action required: your password expires today

Figure 2: Gmail Original Message view. This is the ground truth for send time, sender, recipient, subject, and Message ID.

Quarantine									
Email Files Teams messages									
Refresh ✓ Refuse ⚙ Deny ⚙ Delete messages ⚙ Preview message ⚙ More ⚙									
Filters: Time received: Last 30 days Blocked Sender: Don't show blocked senders									
Time received	Subject	Sender	Quarantine reason	Release status	Policy type	Expires	Recipient	Sender address	Released by
Oct 2, 2026 10:43:30 AM	Action required: your password expires today	phishingmydft@gmail.com	High Confidence Phish	Needs review	Anti-spam policy	Oct 17, 2026 10:43:30 AM	richard.hale@395a...	None	

Figure 3: Quarantine entry in the Defender portal. Reason is High Confidence Phish, policy type is Anti-spam policy, release status is Needs review, and expiry is Oct 17, 2026.

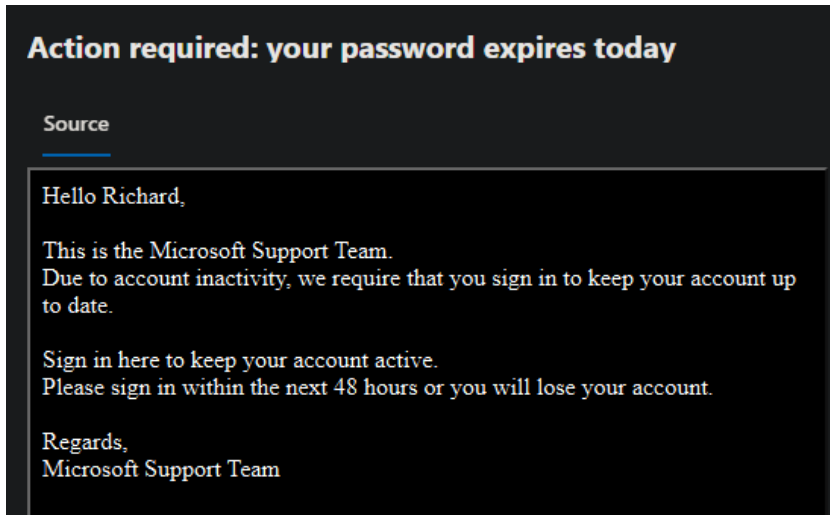


Figure 4: Message source from quarantine. The body is plain text and "Sign in here" is not a link, so there is no URL IOC. Notice the hyperlink is no longer there. It seems as though Microsoft removed it.

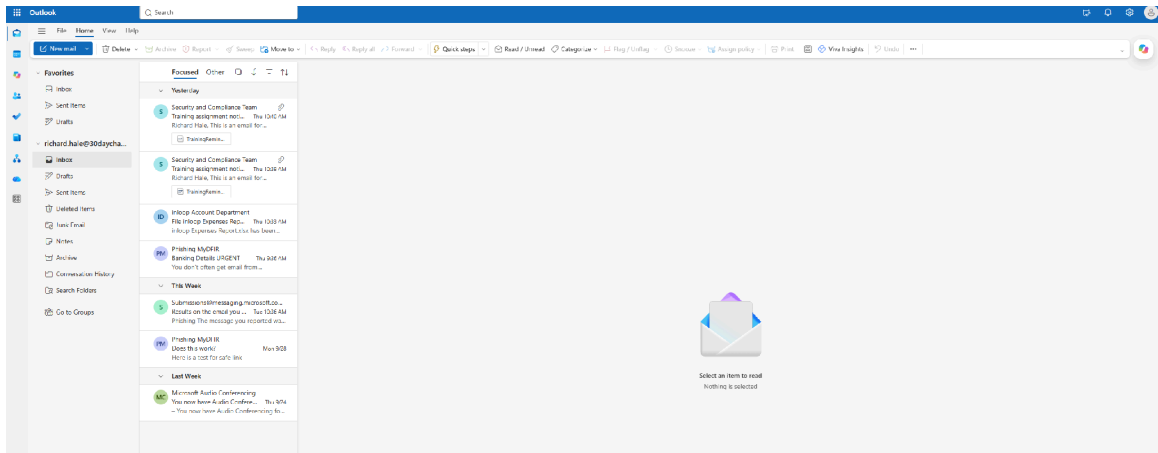


Figure 5: Richard's Outlook mailbox. The lure does not appear in the Focused view, which is consistent with it being held in quarantine rather than delivered.